基于大语言模型的函数级漏洞检测智能体

课程项目开题报告

组长：李柏谚　组员：杨聃、王义卓、孙伊凡、徐培栋

2026 秋季学期·高级软件工程



中国科学院大学

一、研究背景与问题

漏洞披露规模扩大，自动化检测需求迫切

- **漏洞规模持续增长**：2026 年前两个季度新增公开 CVE 漏洞逾 35,000 项，人工代码审计已难以匹配其增长速度。
- **传统静态分析的局限**：其检测能力依赖预定义规则，规则覆盖不足导致漏报，规则过于宽泛导致误报，且难以给出可解释的判定依据。
- **大语言模型的机遇与不足**：LLM 具备代码语义理解与推理潜力，但仍存在两项短板——缺乏软件安全领域知识，且孤立函数不足以支撑安全判定。

研究切入点

构建基于 LLM 的**自主漏洞检测智能体**，以证据驱动的方式完成函数级漏洞判定：先取证、后结论，并使全过程可追溯、可复核。

二、研究目标与关键难点

一项总目标，两项关键技术挑战

总目标

面向 C/C++ 函数代码，输入函数源码及其所属代码仓库地址，输出三项内容：漏洞判定结果——判定理由——分析过程记录。

难点一：LLM 缺乏安全领域知识

即使前沿模型亦难以充分掌握软件安全知识。

对策：构建领域知识 RAG 模块，基于已披露的 CVE 实例建立可检索的知识库，为检测提供历史相似漏洞模式。

难点二：孤立函数难以支撑判定

漏洞常与调用方、被调用方、全局变量等上下文相关，单函数信息不完备。

对策：赋予智能体**仓库按需读取**能力，在证据不足时自主挖掘关联上下文。

设计原则：证据驱动——智能体先基于领域知识初步分析，证据不足时再按需调用仓库工具；检索与读取记录均在界面留痕。

三、系统架构与技术路线

四层解耦结构：界面 → 智能体 → 工具 → 数据

表现层（界面）：输入函数与仓库地址、实时查看分析过程、接收检测报告

智能体层（决策）：推理 → 工具调用 → 观测结果 → 再推理，证据充分方作出判定

工具层（能力）： ① 领域知识检索（RAG） | ② 仓库上下文挖掘（grep / find / 调用关系解析）

数据层（资源）：历史 CVE 漏洞案例库 | 代码仓库版本快照缓存

分层解耦使界面、决策、能力与资源各自独立开发与替换——例如更换底层模型时，其余三层无需改动。

四、核心模块设计

围绕两项关键难点，设计两个核心模块

模块一：领域知识库（RAG）

基于提供的历史案例数据集，通过向量相似度检索相似漏洞模式，供 LLM 参考。

知识来源：成对函数样本（漏洞版 / 修复版）、`cve_desc`（披露描述）、`commit_message`（修复说明）、`cwe`（漏洞类型）及项目元信息。

约束：红线——仅可使用所提供数据集，不得引入额外安全知识。

模块二：代码上下文挖掘

基于修复提交链接获取对应版本仓库快照，为智能体配备内容查找与读取工具，按需溯源。

可挖掘上下文：调用方与被调用方、全局变量声明与使用、类型与宏定义、相关辅助函数。

实现：GitHub API 获取快照，grep / find 检索，Tree-sitter 解析函数定义与调用关系。

约束：严格版本控制——漏洞版仅取父提交版本，修复版仅取提交后版本，且不提供 `git diff`。

五、开发技术栈与工具平台

技术选型：成熟稳定、可控可复现

模块	选型	选型依据
开发语言	Python 3.11	生态完善，前后端与算法实现统一
智能体框架	LangChain（Agent + 工具调用）	框架成熟、示例丰富，支持自主推理与工具调用，满足「自主 Agent」红线要求
知识库与检索	Chroma 向量库 + 中文嵌入模型	本地部署、零外部服务依赖，中文语义检索准确，结果可复现
代码解析	GitHub API + Tree-sitter + grep/find	获取指定版本仓库快照，解析函数定义与调用关系
图形界面	Streamlit	原生支持实时刷新与文件上传，契合过程可视化需求
底层大模型	DeepSeek Flash	代码理解与推理能力较强，接口兼容 OpenAI 协议，成本可控
协作与版本	Git + GitHub（Issue / 分支 / PR）	开发过程留痕，团队贡献可追溯

各模块接口解耦，可在同类方案中替换（如更换底层模型时其余部分无需改动）。

六、开发计划与团队分工

七周三阶段推进，职责分工明确

- **阶段一（W1-W3）基础构建**：需求与数据摸底；历史案例入库、知识库检索可用；仓库查询工具可用（拉取指定版本代码、解析调用关系）。
- **阶段二（W4-W5）系统集成**：打通「先检索 → 再判定 → 按需读仓库」的智能体主流程；完成图形界面与批量检测。
- **阶段三（W6-W7）评测交付**：300 条样本批量评测与迭代调优；撰写技术报告、完成系统演示与结果提交。

团队分工（五人）

李柏谚（组长）总体架构与智能体主流程；**杨聃**领域知识库与检索；**王义卓**仓库查询工具；**孙伊凡**图形界面与批量流程；**徐培栋**评测、集成与文档。

协作方式：数据接口先行，各模块并行开发，最后统一集成与全员评测。